TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HỒ CHÍ MINH (HUTECH)
KHOA CÔNG NGHỆ THÔNG TIN

ĐỀ CƯƠNG ĐỒ ÁN CHUYÊN NGÀNH

Giảng viên hướng dẫn: .....

STT	Họ và tên	MSSV	Ghi chú
1	Phạm Thái Khôi	2380601102	Nhóm trưởng
2	Trần Trọng Thiên	2380602102	
3	Nguyễn Châu Anh Dũng	2380600296	

1. Tên đề tài

Xây dựng AI Agent sử dụng mô hình ngôn ngữ nhỏ phát hiện mối đe dọa dựa trên log Windows.

2. Lý do chọn đề tài

Hiện nay kẻ tấn công thường dùng các công cụ có sẵn của Windows như schtasks, PowerShell, hoặc dùng tài khoản thật bị lộ mật khẩu. Những thao tác này nhìn giống việc quản trị bình thường nên các hệ thống cảnh báo dựa trên luật cố định thường không phát hiện được. Muốn tìm ra, chuyên viên SOC phải tự đặt giả thuyết dựa trên MITRE ATT&CK, ví dụ nếu kẻ tấn công đã tạo tác vụ tự chạy để quay lại máy thì log sẽ ghi lại lệnh schtasks, sau đó lọc log để kiểm tra. Làm thủ công như vậy mất nhiều thời gian và cần người có kinh nghiệm.

Nhóm muốn xây dựng một AI Agent làm thay các bước này. Agent dùng mô hình ngôn ngữ nhỏ chạy trực tiếp trên máy để log không phải gửi ra ngoài và chạy được trên laptop không có GPU rời. Vì mô hình nhỏ dễ trả lời sai nên nhóm không lấy thẳng kết quả của mô hình mà cho code kiểm tra lại bằng chứng trong log trước khi chấp nhận kết luận.

3. Mục tiêu

1. Tìm hiểu MITRE ATT&CK và các sự kiện log Sysmon, PowerShell liên quan đến 8 kỹ thuật tấn công trong phạm vi đề tài.
2. Xây dựng bộ dữ liệu gồm log tấn công đã gán nhãn và log sử dụng bình thường.
3. Tự viết agent bằng Python, không dùng framework có sẵn, với các công cụ: tìm sự kiện, tra lịch sử theo tài khoản hoặc máy, tra cứu kỹ thuật ATT&CK.
4. Viết phần kiểm chứng: kết luận chỉ được chấp nhận khi log có dấu vết đúng với kỹ thuật đó.

5. Nối các phát hiện rời rạc thành chuỗi tấn công theo tài khoản, máy, tiến trình và thời gian.
6. So sánh 4 mô hình nhỏ của 4 họ khác nhau, và so sánh kết quả trước, sau khi fine-tune.

4. Phạm vi

Đề tài làm trên log Windows 10/11, nguồn chính là log Sysmon và log PowerShell (Script Block Logging), mô hình khoảng 3–4 tỷ tham số chạy bằng Ollama. Agent tự chạy toàn bộ quy trình, chỉ đọc log và xuất báo cáo, không tự xử lý tấn công. Đề tài không làm với log cloud, Linux hay lưu lượng mạng. Nhóm chọn 8 kỹ thuật theo các giai đoạn của một chuỗi tấn công điển hình trên Windows, từ lúc xâm nhập đến lúc xóa dấu vết:

Giai đoạn	Kỹ thuật ATT&CK	Kẻ tấn công làm gì
Xâm nhập	T1105 Ingress Tool Transfer	Tải công cụ tấn công về máy
Thực thi	T1059.001 PowerShell	Chạy lệnh PowerShell ẩn, mã hóa
Bám trụ	T1053.005 Scheduled Task	Tạo tác vụ tự chạy chương trình
Bám trụ	T1547.001 Registry Run Keys	Thêm chương trình vào khóa Run để tự khởi động
Bám trụ	T1136.001 Create Account	Tạo tài khoản cục bộ mới
Đánh cắp đăng nhập	T1003.001 LSASS Memory	Đọc bộ nhớ LSASS để lấy thông tin đăng nhập
Lan rộng	T1021.001 Remote Desktop	Đăng nhập sang máy khác qua RDP
Xóa dấu vết	T1070.001 Clear Event Logs	Xóa log Windows

5. Phương pháp và công nghệ dự kiến

Đề tài dùng phương pháp săn tìm mối đe dọa dựa trên giả thuyết. Agent được nhóm tự lập trình bằng Python, không dùng công cụ dựng quy trình hay framework agent có sẵn. Giả thuyết lấy từ MITRE ATT&CK thay vì để mô hình tự nghĩ ra, mọi kết luận đều được code kiểm chứng bằng dấu vết trong log, và các phát hiện được nối lại thành chuỗi tấn công. Nguồn dữ liệu chính là log Sysmon, vì Sysmon ghi lại đầy đủ dòng lệnh và tiến trình cha, giúp bằng chứng chi tiết hơn.

5.1. Quy trình hoạt động của agent

1. Agent chọn một giả thuyết từ danh sách kỹ thuật ATT&CK trong phạm vi.
2. Mô hình chọn công cụ và tham số cần dùng, trả về dưới dạng JSON.
3. Code chạy công cụ, truy vấn log thật và trả kết quả cho mô hình.
4. Mô hình đọc kết quả và quyết định: tìm tiếp, đổi giả thuyết hoặc kết luận.

5. Code kiểm chứng kết luận với dấu vết bắt buộc. Không đạt thì quay lại bước 2 hoặc chuyển sang giả thuyết khác.
6. Kết luận đạt kiểm chứng được ghi vào báo cáo. Agent lặp lại cho đến khi xét hết các giả thuyết.

Cơ chế kiểm chứng. Mỗi kỹ thuật ATT&CK có dấu vết bắt buộc trong log. Code chỉ chấp nhận kết luận khi tìm thấy dấu vết đó. Các phép đếm và so khớp chuỗi (ví dụ số kết nối, tham số dòng lệnh) do code thực hiện, không để mô hình tự làm.

Kỹ thuật	Dấu vết bắt buộc trong log
T1105 Ingress Tool Transfer	Sysmon 1: certutil hoặc PowerShell tải file; Sysmon 3: kết nối ra ngoài; Sysmon 11: file mới được tạo
T1059.001 PowerShell	Sysmon 1: powershell.exe với tham số -enc, -w hidden; PowerShell 4104 (nội dung script)
T1053.005 Scheduled Task	Sysmon 1: lệnh schtasks.exe /create
T1547.001 Registry Run Keys	Sysmon 13: ghi giá trị vào khóa ...\CurrentVersion\Run
T1136.001 Create Account	Sysmon 1: lệnh net user ... /add, hoặc PowerShell 4104 có New-LocalUser
T1003.001 LSASS Memory	Sysmon 10: tiến trình lạ truy cập lsass.exe
T1021.001 Remote Desktop	Sysmon 3: mstsc.exe kết nối tới cổng 3389
T1070.001 Clear Event Logs	Sysmon 1: lệnh wevtutil cl, hoặc PowerShell 4104 có Clear-EventLog

Nối các sự kiện thành chuỗi tấn công. Mô hình chỉ đọc được một lượng văn bản giới hạn mỗi lần nên không thể đọc toàn bộ log nhiều tháng. Khi gặp một sự kiện đáng ngờ, agent dùng công cụ tra lịch sử theo khóa chung như tên tài khoản, tên máy, mã tiến trình hoặc địa chỉ IP; code lọc và tóm tắt lịch sử thành vài dòng cho mô hình đọc, từ đó ghép các phát hiện theo thứ tự các giai đoạn ở mục 4.

5.2. Dữ liệu

- **Log tấn công có nhãn:** phần log Sysmon và PowerShell trong các bộ EVTX-ATTACK-SAMPLES, OTRF Security Datasets và Splunk Attack Data; mỗi tệp log đã được gắn với kỹ thuật ATT&CK tương ứng.
- **Log hoạt động bình thường:** thu thập từ máy của 3 thành viên trong khoảng 2–3 tuần sử dụng hằng ngày (cài Sysmon và bật PowerShell Script Block Logging), xuất bằng Event Viewer. Log bình thường dùng để mô hình học thế nào là bình thường và để đo số lần agent báo nhầm.

– **Tổ chức dữ liệu:** trộn log tấn công vào log bình thường theo dòng thời gian để tạo các kịch bản chuỗi tấn công, chia thành tập huấn luyện và tập kiểm thử theo tỷ lệ 80/20; tập kiểm thử không dùng để fine-tune.

5.3. Đánh giá

– **Chỉ số:** tỷ lệ phát hiện đúng các kỹ thuật tấn công; số lần báo nhầm trên log bình thường; số kết luận bị cơ chế kiểm chứng loại bỏ; khả năng nối đúng chuỗi tấn công; thời gian và RAM cho mỗi phiên săn tìm.

– **So sánh:** giữa 4 mô hình thuộc 4 họ khác nhau; giữa mô hình trước và sau khi fine-tune.

5.4. Công nghệ dự kiến

Thành phần	Công nghệ
Ngôn ngữ lập trình	Python
Vòng lặp agent	Tự lập trình bằng Python, gọi mô hình qua API của Ollama (không dùng framework agent)
Mô hình so sánh	Qwen3 4B (Alibaba), Llama 3.2 3B (Meta), Gemma 3 4B (Google), Phi-4-mini 3,8B (Microsoft)
Kho log	DuckDB (cơ sở dữ liệu chạy trên máy)
Tri thức ATT&CK	Dữ liệu MITRE ATT&CK chính thức tải từ GitHub của MITRE
Fine-tune	LoRA trên GPU miễn phí của Google Colab
Thu log	Sysmon, PowerShell Script Block Logging, Event Viewer
Giao diện	Streamlit
Quản lý mã nguồn	Git, GitHub
Phần cứng	Laptop Lenovo ThinkPad T16 Gen 4, 32GB RAM, không GPU rời

6. Kết quả dự kiến

– Agent phát hiện được 8 kỹ thuật tấn công trên log Sysmon và PowerShell, nối thành chuỗi tấn công, chạy trên laptop và xuất báo cáo kèm bằng chứng.

– Bộ dữ liệu log tấn công và log bình thường.

– Bảng so sánh 4 mô hình và kết quả trước, sau khi fine-tune.

7. Kế hoạch và phân công

Tuần	Công việc	Người làm
1–2	Tải log Sysmon tấn công cho 8 kỹ thuật; cài Sysmon thu log bình thường; viết code chuyển log vào DuckDB	Thiên (cả nhóm thu log)
3–4	Vòng lặp agent, các công cụ và phần kiểm chứng; chạy thử	Khôi

Tuần	Công việc	Người làm
	với 5 kỹ thuật lõi	
5	Thêm 3 kỹ thuật còn lại; dựng kịch bản chuỗi tấn công	Khôi, Thiên
6	Chạy 4 mô hình, đánh giá lần 1	Dũng
7–8	Chuẩn bị dữ liệu huấn luyện, fine-tune trên Colab, đánh giá lại	Dũng, Khôi
9	Giao diện, báo cáo tự động, sửa lỗi	Dũng
10	Viết báo cáo, slide, quay video demo	Cả nhóm

Khôi làm nhóm trưởng, phụ trách agent và phần kiểm chứng. Thiên phụ trách dữ liệu và công cụ tra cứu log. Dũng phụ trách so sánh mô hình, fine-tune và giao diện.